

E-ITS Selgitus: Meetmete tasemed vs. Organisatsiooni turbeviisid

Sinu arusaam on peaaegu täiesti õige, kuid siin on üks kriitiline erinevus **meetme taseme** (kataloogis) ja **turbeviisi** (organisatsiooni skoobis) vahel. E-ITS-is on need kaks eri tasandi mõistet.

1. Meetmete tasemed kataloogis (EitsCatalogMeasure)

E-ITS etalonoturbe kataloogis (`eits_catalog_measures`) on igal üksikul meetmel kindel **tase** (*level*). See näitab meetme rangust ja kohaldatavust. Tasemeid on kolm:

- 1. **Põhimeede (tähis `BASE` / kataloogis ajalooliselt ka `M` - *Basic Measure*):**
 - **Mis see on:** Elementaarne turvameede, mis peab olema rakendatud igas organisatsioonis. See kaitseb tüüpiliste küberohtude eest ja loob vundamendi.
 - *Näide:* "Paroolide miinimumpikkuse nõue."
- 2. **Standardmeede (tähis `STANDARD` / kataloogis ka `S` - *Standard Measure*):**
 - **Mis see on:** Meede, mida rakendatakse tavapärase kaitsetarbe tagamiseks. Viib turvalisuse vastavusse standardiga ISO 27001.
 - *Näide:* "Kaheastmelise autentimise kohustuslik kasutamine kõigil välisliidestel."
- 3. **Kõrgmeede (tähis `HIGH` / kataloogis ka `H` - *High-level Measure*):**
 - **Mis see on:** Meede väga suure kaitsetarbega varade või elutähtsate teenuste kaitsmiseks.
 - *Näide:* "Riistvaraliste krüptomoodulite (HSM) kasutamine võtmehalduseks."

2. Organisatsiooni turbeviisid (Tenants.mode_of_protection)

Turbeviis (Mode of Protection) on valik, mille teeb asutuse juhtkond selle kohta, **kuidas** ja **mis mahus** etalonturvet organisatsioonis juurutatakse.

Siin ongi koht, kus mõiste "tuumik" mängu tuleb. **"Tuumikmeede" puudub – on olemas Tuumikuturve!**

Turbeviis (<i>Mode of Protection</i>)	Mida see praktikas tähendab?	Milliseid meetmeid rakendatakse?
Põhiturve (<i>Baseline Security</i>)	Organisatsiooni kõigi äriprotsesside kaitsetarve on <i>normaalne</i> .	Rakendatakse ainult Põhimeetmeid (<code>BASE</code>).
Standardturve (<i>Standard Security</i>)	Organisatsioonis on suurema kaitsetarbega protsesse ja ressursse on piisavalt, et kogu asutus turvata kõrgel tasemel.	Rakendatakse Põhimeetmeid (<code>BASE</code>) + Standardmeetmeid (<code>STANDARD</code>).
Tuumikuturve (<i>Core Security</i>)	Organisatsioonis on kriitilisi protsesse (suur kaitsetarve), kuid ressursse on vähe. Seetõttu piiritletakse ainult kriitiline tuumik (<i>core scope</i>).	Tuumikule (nt patsiendiandmete süsteem) rakendatakse Standardturvet (<code>BASE</code> + <code>STANDARD</code>).

Ülejäänud organisatsioonile rakendatakse esialgu ainult **Põhiturvet** (`BASE`).

3. Kuidas see Sinu andmebaasi skeemis kajastub?

Sinu andmebaasi skeemis kajastub see loogika järgmiselt:

1. **Meetme tase on kirjas kataloogis:** Tabelis `eits_catalog_measures` on väli (näiteks `level` või `type`), mille väärtuseks on kas `'BASE'` , `'STANDARD'` või `'HIGH'` .
2. **Turbeviis määratakse kliendi profiilis:** Tabelis `tenants` (või seotud turvaprofiilis) on väli `mode_of_protection` , mille väärtuseks saab kasutaja valida kas `'BASELINE'` , `'STANDARD'` või `'CORE'` .

Genereerimise loogika (Backend filter):

Kui süsteem genereerib kasutajale IMR-i (`imr_items`), siis filtreeritakse kataloogist ainult need meetmed, mis vastavad kliendi valitud turbeviisile:

- Kui tenant valis `'BASELINE'` , teeb süsteem päringu: `WHERE measure.level = 'BASE'` .
- Kui tenant valis `'STANDARD'` , teeb süsteem päringu: `WHERE measure.level IN ('BASE', 'STANDARD')` .
- Kui tenant valis `'CORE'` , siis:
 - Tuumikusse kuuluvate sihtobjektide puhul: `WHERE measure.level IN ('BASE', 'STANDARD')` .
 - Tuumikust välja jäävate sihtobjektide puhul: `WHERE measure.level = 'BASE'` .